Protecting useful SaaS from REA-assisted reconstruction

White paper | Exact workflows and private contexts | 19 October 2026

The result and its boundary

Keeping genuinely private customer pricing rules behind consistent server permissions reduced other-context within-1% reconstruction from 100.0% to 0.0% in this study, a 100.0 pp mean reduction. Exact legitimate workflow actions passed 1,008/1,008. The same agents still reconstructed their own permitted pricing within 1% on 100.0% of heldouts. This protects private context; it does not stop copying the behaviour a customer can already use.

The bound-context design passed the predeclared useful private-context protection screen on all six targets. This is a practical result for protecting private customer configurations. It is not proof that REA cannot recreate a product's visible interface, ordinary workflow or an authorised customer's behaviour.

What REA is doing

REA means Reverse Engineer Anything. In this research, the pinned 6.7.0 browser capability opens an owned synthetic SaaS in Chrome, executes UI actions and captures delivered page structure, JavaScript and network request/response bodies. An LLM chooses inputs, compares outputs, fits candidate numerical rules and probes uncertain transitions. Repeating that process can recover a server-side calculation without reading its source. An export or background job can be as informative as the main quote screen.

The new test uses 24 fresh gpt-6-astra agents with max reasoning, numerical fitting and up to 192 attempted requests each. REA is the observation tool; the agent and bounded fitter perform the reconstruction. These agents do not have every upstream REA capability or unrestricted external tools. The percentages measure numeric prices on synthetic targets, not a whole SaaS clone. Read the pinned mechanism explanation and upstream browser guide.

Why exact quotes need a different defence

Earlier work in this repository found that rounding and caps could reduce exact matches but often left useful approximate reconstruction. The previous fitting study recovered capped exact functions within 1% on 98.8% of unseen inputs. A graceful rounding fallback preserved estimate workflows but still allowed 99.9% within-1% reconstruction. Those studies preserved only two pre-approved exact quote quantities. They did not prove arbitrary new exact quotations stayed useful.

The new design leaves exact calculations available at every legitimate quantity. Its boundary is which customer's rules an identity may query. Real negotiated terms, private customer configuration and non-public data should remain attached to server-owned entitlements. Reducing exposure to unrelated contexts can protect those private assets while leaving the customer's own work intact. If the same global function serves everyone, those permissions cannot hide it from someone who can query their own copy.

Evidence scorecard

Policy	Own within 1%	Other within 1%	Other within 5%	Exact workflow actions
Client-selected context (unsafe)	100.0%	100.0%	100.0%	1,008/1,008
Bound private contexts	100.0%	0.0%	4.0%	1,008/1,008
Bound context + leaky export	100.0%	100.0%	100.0%	1,008/1,008
Bound context + shared rule	100.0%	100.0%	100.0%	1,008/1,008

Means across six paired targets, 128 common unseen quantities each. Within 1% and within 5% are error tolerances relative to exact price. The bound arm’s mean other-context reduction was 100.0 pp, ranging from 100.0 pp to 100.0 pp across targets. All 24/24 predictors were valid; 0 failed. The shared-rule control intentionally changes the own function to equal other, so it tests transfer risk rather than an identical-own-output comparison.

A deliberately missed export check restored other-context accuracy to 100.0%. Sharing the same underlying rule gave 100.0% accuracy despite correct access denials. Agents were explicitly told about the export weakness and shared-rule relationship in their respective controls. These are informed failure demonstrations, not blind vulnerability-discovery rates. A permission refusal by itself does not prove that inference has stopped.

What remained useful

The exact-workflow evaluation covered both customers in every policy and target: 48 HTTP journeys, 4,032 actions. Customers created 12 arbitrary, previously unapproved quotes, revised each quantity, accepted the updated exact amount, retrieved and exported it, and retrieved an exact background export. Same-customer session changes were included. Bound private contexts passed 12/12 journeys and 1,008/1,008 actions. No query cap, rounded amount, restricted catalogue or operator approval was applied to these legitimate actions. Protected export requires an existing quote ID; direct quantity-to-export is unavailable even for own context, so that convenience path requires creating a quote first. The usefulness result covers the stated quote lifecycle, not every possible export shortcut.

For a concrete retained journey on target-01, the customer created quantity 31 at GBP 953.56, revised it to quantity 44 at GBP 1353.44, accepted version 2, then received that exact amount again from direct export and the background job. This is an observed new quote, not a fixed approval catalogue. Across all policies, 3,456/3,456 price-bearing responses passed exact-price and record checks. This establishes synthetic task correctness. It does not establish human satisfaction, accessibility, business suitability or production performance. If cross-customer exploration is a promised feature, withholding it has a product cost and must not be described as free protection.

What developers should implement

- Derive authorised business contexts from the authenticated identity on the server. Treat tenant, contract, pricebook and quote IDs from the client as lookup requests, not proof of permission. Intersect requested contexts with server-owned entitlements.

- Apply the same object and action check to quote creation, aliases, previews, revisions, acceptance, exports, job submission and job retrieval. The failed export control shows why one omitted check matters.

- Keep private rules and configuration off the client and out of unnecessary response fields. Return the exact result and necessary business record. This does not hide the permitted function from inference.

- Use version-checked draft updates and an exact accepted snapshot. Export that authorised snapshot; do not turn export parameters into a new unrestricted pricing calculator. Recheck current permission when serving queued results.

- Test known foreign object IDs, extra fields, stale versions, post-acceptance mutation, session replacement and revocation alongside successful arbitrary exact workflows. Measure private numeric disclosures as well as HTTP refusals.

The fixture demonstrates these components together. It does not assign separate reconstruction percentages to response minimisation, version checks or snapshots. The general object-access principle is also described by OWASP API1:2023.

What architects should design

Make the protected asset explicit: private contract parameters, customer-specific configuration, proprietary live data, or a truly global algorithm. Separate contexts where the business already requires separation. Keep policy consistent across services, caches, jobs, support tooling and exports. Design entitlement provisioning so an observer cannot simply self-enrol into every protected context. Account compromise, reseller access and colluding customers change the threat model.

The shared-rule control is a warning about correlation. Private contexts are valuable only to the extent that their behaviour is not recoverable from other permitted contexts or public data. Do not promise that tenancy alone hides a global rule. A supplementary predictor with the correct family and all parameter ranges achieved 1.7% within 1% without private observations; real prior knowledge can matter.

Production deployment also requires durable policy state, atomic quote transitions, replay handling, TLS, maintained identity/session controls, CSRF protection where applicable, observable revocation and independent review. These are implementation recommendations, not claims established by the in-memory laptop fixture.

What product managers should require

Define the exact tasks that must remain available before choosing a defence. For a quote product, include arbitrary legitimate creation, revisions, accepted prices and exports, not just two fixed examples. Track completion rate, pence accuracy, latency, support burden and denied legitimate tasks. Use customer entitlements that match real business ownership. Do not invent opaque pricing variation merely to frustrate copying.

Set separate acceptance criteria for unauthorised extraction, own-customer behavioural imitation and workflow usefulness. Here the protected design required zero other-context numeric disclosure, a within-1% reduction of at least 20 percentage points on every target, valid agent outputs and 100% exact workflow success. The observed result was: The bound-context design passed the predeclared useful private-context protection screen on all six targets. A requirement to stop all copying of visible features was not met and should not be implied.

How strong is the evidence?

The study contains 338 real REA captures, 4,608 matched business responses, 9,892 checked body hashes, 88 numerical fits and 6,144 unseen predictions. All target commitments, fresh agent transcripts, predictor hashes, scores and utility rows are available. Predictors were frozen before targets and holdouts were disclosed. Overall REA capture status can be incomplete; the verifier checks the specific request, response and DOM evidence used for every observation.

A separate two-world test compared 24,108 pairs of response bodies while changing only hidden other-context rules. The responses matched. This supports the source-level explanation of why the tested paths do not reveal those rules. It is not a side-channel, timing or arbitrary exploit proof. Sequential IDs in the teaching fixture could reveal concurrent activity counts; private activity confidentiality was not tested. The informed-prior analysis is explicitly supplementary numerical work, not additional agent evidence.

All 6/6 protected agents copied their own model as an explicitly uncertain other-context fallback. The 0% score describes those submitted guesses; it is not a bound on every attacker. The better-informed numerical baseline above scored 1.7% within 1%. Only six targets from three simple pricing families and one stochastic agent per cell were tested. The operator controls the synthetic target generator and harness. There is no independent red-team certification, unlimited-budget result, UI-cloning score or guarantee against collusion. Own-context within-1% reconstruction remained 100.0% in the protected arm. These limits are part of the result.

Laptop safety and publication

All application fixtures used loopback and synthetic credentials. Agent threads had no shell, host environment, external browsing, inherited instructions or extra MCP access; their only observations came through bounded REA tools. Raw account/engine events stayed private. No laptop security setting was weakened. Publication checks cover personal paths and emails, recognisable credentials, decoded network bodies, PDF metadata and archive contents. Generic loopback addresses are retained for reproducibility. This is scoped risk reduction, not a comprehensive laptop audit.

Use and extend this work

Use the full effectiveness report for per-target scores, effort, exact matches, full-domain diagnostics, proof boundaries and evidence links. The reproduction guide explains offline verification and new runs. Read release checks for the actual publication audit. Both the developer pack and full research pack are available from REA War Games.

The next useful experiments are repeated independent agents, larger numbers of genuinely distinct private contexts, realistic correlated contracts, public prior datasets, colluding authorised accounts and whole-product reconstruction tasks. Preserve exact customer workflows and publish failing controls. This work supports a concrete way to reduce private-context reconstruction risk while retaining exact quotes; it does not make observable SaaS behaviour uncopyable.